PORTFOLIO CASE STUDY

Vulnerability Assessment Report

Qualitative access-control risk analysis for a publicly accessible MySQL database server

Prepared by: Eduardo Land
Artifact type: Scenario-based educational assessment
Method: Course-adapted 3 x 3 qualitative risk matrix
Reference: NIST SP 800-30 Rev. 1
Version: 1.0 | August 2026

> **Central exposure:** The database server has been publicly accessible since the fictional company's launch three years ago, increasing the attack surface for unauthorized parties.

System Description

The assessed asset is a remote database server used by employees in multiple locations to query information and identify potential customers. The course-provided environment describes a Linux server with 128 GB of memory running MySQL, stable IPv4 network connectivity, interactions with other servers, and SSL/TLS-protected connections. The database server has remained publicly accessible since the company's launch three years ago; that exposure is the central vulnerability considered in this report.

Scope

This assessment focuses on the database server's current logical access controls and the potential effect of the identified exposure on confidentiality, integrity, and availability. It follows the template's three-month assessment period and uses the course-provided adaptation of NIST SP 800-30 Rev. 1 to structure a qualitative risk analysis. Physical security and unrelated IT systems are not assessed in this report.

Purpose

The database is valuable to the company because employees around the world use it to find potential customers. Since the database server is publicly accessible, a vulnerability assessment is necessary to identify and reduce the risks associated with unauthorized access. A data breach could expose sensitive information, damage the company's reputation, and potentially cause financial losses. If the server became unavailable, business operations would also be affected because employees would be unable to access the data they need to find new customers.

Risk Assessment

The table prioritizes three threat source and threat event combinations that are plausible within the stated scenario and directly related to the server's public exposure.

Threat Source	Threat Event	Likelihood	Severity	Risk Score
Outsider - Hacker	Obtain sensitive information via exfiltration	3	3	9
Competitor	Perform reconnaissance and surveillance of the organization	2	2	4
Outsider - Hacker	Conduct Denial of Service (DoS) attacks	3	3	9

Scoring note: *Likelihood and severity use the course-provided 1-3 scales; risk score equals likelihood x severity.*

Approach

The risks were selected based on the public accessibility of the database server and the potential impact on business operations. Hackers were treated as a major threat source because they could attempt to exfiltrate sensitive data or disrupt access through a Denial of Service (DoS) attack. A competitor could also perform reconnaissance to gather information that may support future activity. Likelihood and severity scores reflect the server's exposure and the potential effect of each event on confidentiality and availability. This is a qualitative, scenario-based assessment; no technical testing was performed.

Remediation Strategy

Public access to the database server should be removed, allowing connections only from authorized users and systems through approved network paths. Strong authentication, including multi-factor authentication (MFA) where supported, and role-based access controls should enforce the Principle of Least Privilege. Defense in depth should combine network restrictions, database permissions, and protective controls that reduce exposure to reconnaissance, exfiltration, and service disruption. Centralized logging and auditing should record authentication attempts, privilege changes, and relevant database activity for review and alerting. Access rights and control effectiveness should be reviewed regularly.

> **Implementation note:** SSL/TLS-protected connections are already part of the stated environment. The primary remediation priority is therefore reducing public exposure and strengthening access governance, while retaining encrypted connections as an existing layer of protection.

Assessment Limitations

This report is based solely on the fictional scenario and supplied system description. It does not include direct configuration review, vulnerability scanning, log analysis, data classification, architecture validation, or penetration testing. No specific exploit path, compromised credential, malware, prior breach, or regulatory violation is assumed. The scores should be treated as qualitative prioritization for decision-makers and validated through an authorized technical assessment before implementation decisions are finalized.

Sources

National Institute of Standards and Technology. NIST Special Publication 800-30 Revision 1: Guide for Conducting Risk Assessments. September 2012.

Google/Coursera. Course-provided Vulnerability Assessment Report template, scenario, and adapted NIST SP 800-30 Rev. 1 supporting material.